Choosing AI tools for research data at UCI

Guidance on the use of chat and coding agents with UCI data

Dr. Peter Chang | Director, Institute for Precision Health, UCI Health Affairs

Purpose and status. Formal UCI policy specific to agentic AI tools is currently evolving. The recommendations below represent a conservative interpretation of existing information-security policy and research configurations approved for prior institutional use, including UCI Health ITS-managed servers and enterprise AWS. This document informs, but does not substitute for, institutional review. For research data at P2–P4, consult your IRB and the contacts on page 2 before proceeding.

Background

Cloud-hosted language models process all transmitted context. In interactive *chat*, data exposure is limited to explicit user prompts. In contrast, an autonomous coding *agent* operates across local files and terminal sessions, transmitting code excerpts, command outputs, and environment logs to the model. Data exposure is therefore governed by the entire working directory, not merely what the user types. Three terms are used throughout:

- **Model provider**: The service hosting and executing model inference (accessed by subscription or per-token API).
- **Harness**: The client-side software that reads local files, executes shell commands, and manages API calls on the user's behalf (vendor-specific or vendor-neutral).
- **Route**: The integrated combination of provider, harness, and account credentials (e.g., ZotGPT accessed via a vendor-neutral harness). Routes represent the auditable unit evaluated for protection-level compliance.

Recommended order of decisions

1. **Classify the data** using UCI protection levels. Sensitivity is determined by the highest-risk file in the working directory.
2. **Select an approved route** validated for that tier (table below; details on page 2). Regulatory compliance is primarily governed by provider terms and account type, with the harness selected to fit.
3. **Verify the setup** against the pre-use checklist on page 2, securing IRB approval for human-subjects research.

Approved routes by protection level

UCI protection level	Any provider	ZotGPT	Local HS server	Enterprise AWS
P1 Public Published research, public-website data, open de-identified datasets	**Yes**	**Yes**	**Yes**	**Yes**
P2 Internal Unpublished drafts, meeting notes, UCI de-identified research or patient data	**No**	**Yes** IRB first	**Yes** IRB first	**Yes** IRB first
P3 Moderate Student (FERPA) and personnel records, export-controlled research	**No**	**Yes** IRB first	**Yes** IRB first	**Yes** IRB first
P4 Highest PHI, identifiable human-subjects data, SSNs, genetic or biometric data	**No**	**No**	**Yes** IRB + approved setup	**Yes** IRB + approved setup

Guiding principles. (a) For research data at P2–P4, secure IRB protocol approval before deploying agentic tools. (b) *Data aggregation risk*: Combining lower-risk fields, unstructured clinical text, or high-dimensional attributes can re-identify de-identified records (mosaic effect); when uncertain, assign the higher tier. (c) Publicly released de-identified datasets are P1; de-identified data held internally at UCI remain P2. (d) Prototype workflows using synthetic or public data (P1) until formal approvals are secured.

Routes in practice

Data governance is dictated primarily by the model provider's institutional terms. Client harnesses govern local execution; beyond P1, institutional options are strictly constrained.

Route (max. level)	Chat	Agent	Billing
Any provider (P1)	Commercial chat interfaces, including personal accounts.	Vendor-proprietary harnesses on subscription (e.g., Claude Code, Codex CLI, Gemini CLI), or vendor-neutral harnesses with an API key.	Subscription or metered per-token billing.
ZotGPT (P3)	ZotGPT Chat portal, open to faculty, staff, and students.	Vendor-neutral harness (e.g., Kiro CLI, OpenCode) configured to the ZotGPT API. Requires API provisioning via ServiceNow.	Metered per token (institutional credits available).
Local HS server (P4)	Uncommon; self-hosted web interfaces (e.g., Open WebUI) may be deployed manually.	Vendor-neutral harness connected to a local model hosted on a server managed with UCI Health ITS.	Hardware capital and local administration.
Enterprise AWS (P4)	Uncommon; private web frontends may be deployed within AWS enclaves.	Kiro with enterprise (UCI) single sign-on (multi-model support), or a vendor-neutral harness connected to Amazon Bedrock.	Kiro: subscription. Bedrock: per token.

Notes

- **Account type dictates protection tier.** Kiro via personal login is strictly a P1 route; P4 applies exclusively when authenticated via UCI enterprise SSO within UCI's managed AWS environment.
- **Portability of vendor-neutral harnesses.** Open-source harnesses operate interchangeably across ZotGPT, Amazon Bedrock, and local models by updating endpoint URLs and keys. Above P1, the choice is between turnkey enterprise routes and configurable open-source tools.
- **Harness security and egress inspection.** Client harnesses must be evaluated alongside the model provider. Investigators must verify outbound endpoints, disable telemetry, and confirm local transcript paths, as harnesses serve as the primary egress route for workspace files.
- **Subscription vs. programmatic decoupling.** Commercial subscriptions are generally tied to proprietary vendor harnesses (standard for P1 workflows), whereas API-driven access decouples client execution from underlying model inference.
- **ZotGPT regulatory boundaries.** ZotGPT is strictly prohibited for PHI or P4 data; human-subjects research requires IRB authorization. Confirm custom endpoint support and model availability prior to deployment. Because agentic loops execute recursive queries, enforce hard spend caps.

Further reading. Harnesses and models, Costs: subscriptions and APIs, Privacy and data handling, Sandboxing.

Pre-use checklist

- ☐ What is the highest protection level of any file accessible within this working directory?
- ☐ Does this project involve human subjects, and does IRB protocol approval cover computational AI tools?
- ☐ Are both the model provider and the client harness approved for this data protection level?
- ☐ Is the session authenticated via an institutional or enterprise account rather than a personal login?
- ☐ Can the agent work from a data schema, dictionary, or sample rather than the complete dataset?
- ☐ Are session transcripts and logs stored securely and excluded from version control (.gitignore)?

Contacts and links

- **Local HS-approved server:** UCI Health ITS, its.health.uci.edu. Requests are submitted through ServiceNow.
- **Enterprise AWS (Kiro, Bedrock):** Mike Glover, UCI AWS Cloud Architect, gloverm@hs.uci.edu.
- **ZotGPT:** API overview, request API access (ServiceNow), API portal, privacy notice.
- **UCI protection levels:** security.uci.edu/program/classification/protection-levels.
- **Background reading:** peterchang77.github.io/agent-ai-skills.

Policies, pricing, and approvals change; consult the linked UCI pages for current terms.